Liebe Juntagrista

Die KI ist eine Realität im IT-Bereich mit welchem auch wir uns auseinandersetzen müssen. Angriffe im Internet haben haben zugenommen, da es nun viel einfacher ist Sicherheitslücken zu finden und auszunutzen.

Dazu ein gerade erschienener Artikel: https://threema.com/de/blog/welle-von-cyberangriffen-okt-2026

Juntagrico profitierte davon, dass es eine Nischenanwendung ist und es darum relativ wenige Daten zu holen gibt. Es ist also nicht das lukrativste Ziel für einen Angriff. Wenn aber ein Einbruch fast schon „versehentlich“ passieren kann, hilft es auch nicht mehr so viel „unauffällig“ zu sein.

Auch wenn die Mitgliederdaten auf den ersten Blick nicht so spannend zu sein scheinen, werden diese nach dem Diebstahl gerne weiterverkauft. Mit den Daten können u.a. Phishing-Angriffe auf eure Mitglieder durchgeführt werden. Jemand könnte z.B. gefälschte Rechnungen in eurem Namen verschicken. Durch die korrekten Personendaten können diese glaubwürdig wirken.

Die Sicherheit einer Web-Anwendung hängt von deren Code, der Infrastruktur aber insbesondere von den Anwender:innen ab.

Demnächst wird Juntagrico 2.0.11 veröffentlicht, welches ein paar Sicherheitslücken schliesst, aber auch Funktionen zur Verfügung stellt, um Juntagrico besser vor Angriffen zu schützen. **Dieses Briefing gibt dir einen Überblick, was du schon vor diesem Update tun kannst, um die Sicherheits deiner Juntagrico-Instanz zu erhöhen.**

Neueste Version von Juntagrico verwenden

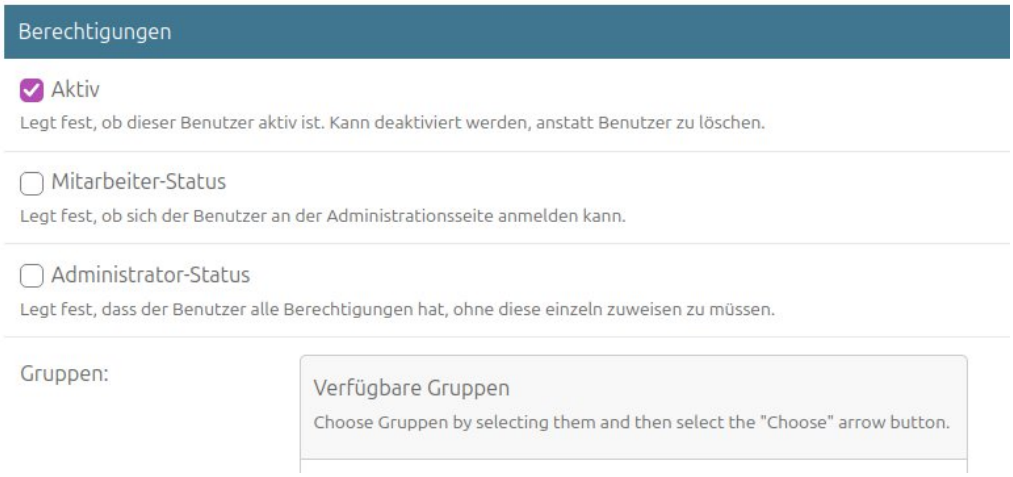
Alle Versionen von Juntagrico, die älter sind als 2.0, basieren auf Django 4.2 (oder älter), welches keine Sicherheitsupdates mehr erhält. Aktualisiere deshalb so bald wie möglich auf Juntagrico 2.0 (Django 5.2) und verwendet jeweils das neuste Sicherheitsupdate: Stand heute ist das **2.0.10**.

Zugänge einschränken

Viele Angriffe zielen darauf ab, die Zugangsdaten eines Mitarbeiters zu erlangen, z.B. via Phishing oder durch erraten des Passworts. Wer so Zugang zu einem Login erhält kann damit so viel Schaden anrichten, wie dieses Konto zulässt. Darum sollten die Zugänge für jedes Konto so weit wie möglich eingeschränkt werden.

Berechtigungen sparsam verteilen

Jedes Konto in Juntagrico sollte nur die nötigsten Berechtigungen haben.



Der Administrator-Status gibt vollen Zugriff und sollte nur wenigen Personen vorbehalten sein.

Der “Mitarbeiter-Status” sollte auch sparsam vergeben werden. Dieser Status erlaubt auch das Nachahmen von anderen Personen (siehe unten).

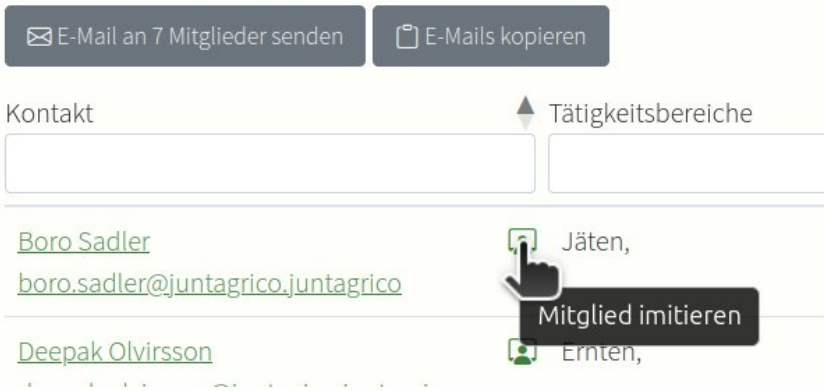
Personen welche sich um die Mitgliederverwaltung oder andere Aufgaben kümmern, sollten jeweils nur die nötigsten Berechtigungen haben, die sie für ihre Aufgabe brauchen.

Erfahre mehr über Berechtigungen in Juntagrico:
https://juntagrico.readthedocs.io/de/latest/reference/permissions.html

Impersonate-Funktion limitieren

Juntagrico ermöglicht den Usern mit „Mitarbeiter-Status“ andere Personen zu imitieren. Also sich als diese auszugeben. Dies kann nützlich sein, um für ein Mitglied eine Aktion auszuführen, nachdem diese eine entsprechende Anfrage per E-Mail eingereicht hat.

Es ermöglicht aber auch das Imitieren von anderen Personen mit „Mitarbeiter-Status“. Somit haben alle Personen mit „Mitarbeiter-Status“ indirekt so viele Berechtigungen, wie die Person mit den meisten Berechtigungen, ausgenommen jene mit „Administrator-Status“.



Beschränke darum die Impersonate-Funktion auf möglichst wenige Personen.
Um nur jenen mit „Administrator-Status“ die Verwendung zu erlauben, definiere dies im settings.py:

```
IMPERSONATE = {
    'REQUIRE_SUPERUSER': True
}
```

Um genauer einzustellen, wer die Funktion nutzen kann und welche Nutzer:innen nachgeahmt werden können, kannst du die Einstellungen 'CUSTOM_ALLOW' und 'CUSTOM_USER_QUERYSET' verwenden.

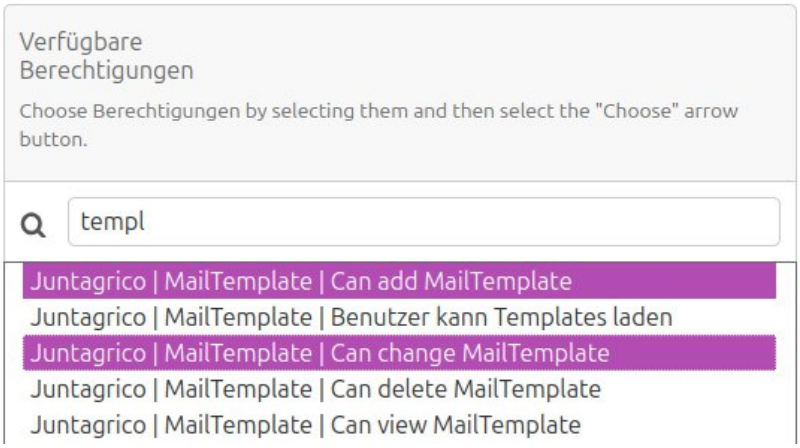
https://pypi.org/project/django-impersonate/

Ab Juntagrico 2.0.11 wird es möglich sein, die 'impersonate'-App komplett zu deaktivieren, falls du diese nicht brauchst.
Es wird zudem einige Helferfunktionen mitliefern, um die Einstellung von 'CUSTOM_ALLOW' und 'CUSTOM_USER_QUERYSET' zu vereinfachen.

E-Mail-Templates sperren

In E-Mail-Templates kann beliebiger python Code definiert und später ausgeführt werden. Dies ist offensichtlich gefährlich und wird in künftigen Juntagrico-Versionen durch eine sicherere Variante ersetzt.

In der Zwischenzeit solltest du einschränken, wer die E-Mail-Templates bearbeiten kann. Stelle sicher, dass möglichst niemand die Berechtigung zum hinzufügen oder bearbeiten von E-mail-Templates hat:



Personen mit „Administrator-Status“ haben die Berechtigung automatisch.

Ab Juntagrico 2.0.11 wird die Bearbeitung der E-Mail-Templates grundsätzlich gesperrt und muss explizit via settings.py freigeschaltet werden.

Juntagrico-pg deaktivieren

Dieses Addon erlaubt die Ausführung von beliebigen SQL-Anweisungen in deiner Datenbank. Falls du das regelmässig brauchen solltest, öffne ein Feature-Request in Juntagrico, um deinen Anwendungsfall abzudecken.

Das Sicherste ist es, dieses Addon zu deinstallieren.

https://github.com/juntagrico/juntagrico-pg

Rich-Text bereinigen

Falls du den Rich-Text-Editor für das Admin-Interface aktiviert hast, kann jemand mit Schreibzugriff dort HTML einfügen, welches z.B. Javascript enthält. Wenn jemand eine Seite besucht, die den entsprechenden Text anzeigt, würde dieser Code im Browser ausgeführt werden.

https://juntagrico.readthedocs.io/en/latest/intro/advanced.html#rich-text-editor

Das HTML sollte darum vor dem Speichern bereinigt werden.

Diese Bereinigung wird in Juntagrico 2.0.11 integriert sein. Stelle für den Moment sicher, dass möglichst wenige Personen Abo-Typen, Depots, etc. bearbeiten können.

Brute-Force-Attacken abwehren

Oft können schwache Passwörter erraten werden. Dazu probieren Angreifer automatisch die gängigsten Passwörter beim Login aus.

Dem kann entgegengewirkt werden, indem die Loginversuche limitiert werden.

Dazu kann django-axes verwendet werden:

Füge `django-axes[ipware]~=8.3.1` im requirements.txt hinzu

Dann im Settings.py:

Füge `"axes"` zu den `INSTALLED_APPS` hinzu

Ergänze `"axes.backends.AxesStandaloneBackend"` als ersten Eintrag in `AUTHENTICATION_BACKENDS`

Ergänze `"axes.middleware.AxesMiddleware"`, als letzte Eintrag bei `MIDDLEWARE`

Und ergänze diese Einträge:

```
AXES_FAILURE_LIMIT = 3
AXES_COOLOFF_TIME = timedelta(minutes=30)

AXES_IPWARE_META_PRECEDENCE_ORDER = [
    'HTTP_X_FORWARDED_FOR',
    'REMOTE_ADDR',
]
```

Damit wird eine IP nach 3 fehlgeschlagenen Logins für 30 Minuten gesperrt.

Sichere Passwörter verwenden

Alle Massnahmen helfen nicht, wenn sich ein Passwort einfach erraten lässt.

Für den Moment kannst du deine Admins und Mitarbeiter:innen nur daran erinnern.

Ab Juntagrico 2.0.11 wird es eine einfache Einstellung geben, um bei allen Konten mit “Mitarbeiter-Status” oder “Administrator-Status” ein sicheres Passwort zu erzwingen.

Deployment-Zugriff einschränken

Die Schreibrechte auf eurem Github-Repo und insbesondere der Zugriff auf das admin.juntagrico.science sollte auf wenige qualifizierte Personen beschränkt bleiben. Wer den Code kontrolliert, kann sich sehr einfach Zugang zu den Daten verschaffen.

Für den Zugriff auf admin.juntagrico.science ist künftig vorgesehen dies mit 2FA besser zu schützen.